Hacking Moodle by PHP2Shell

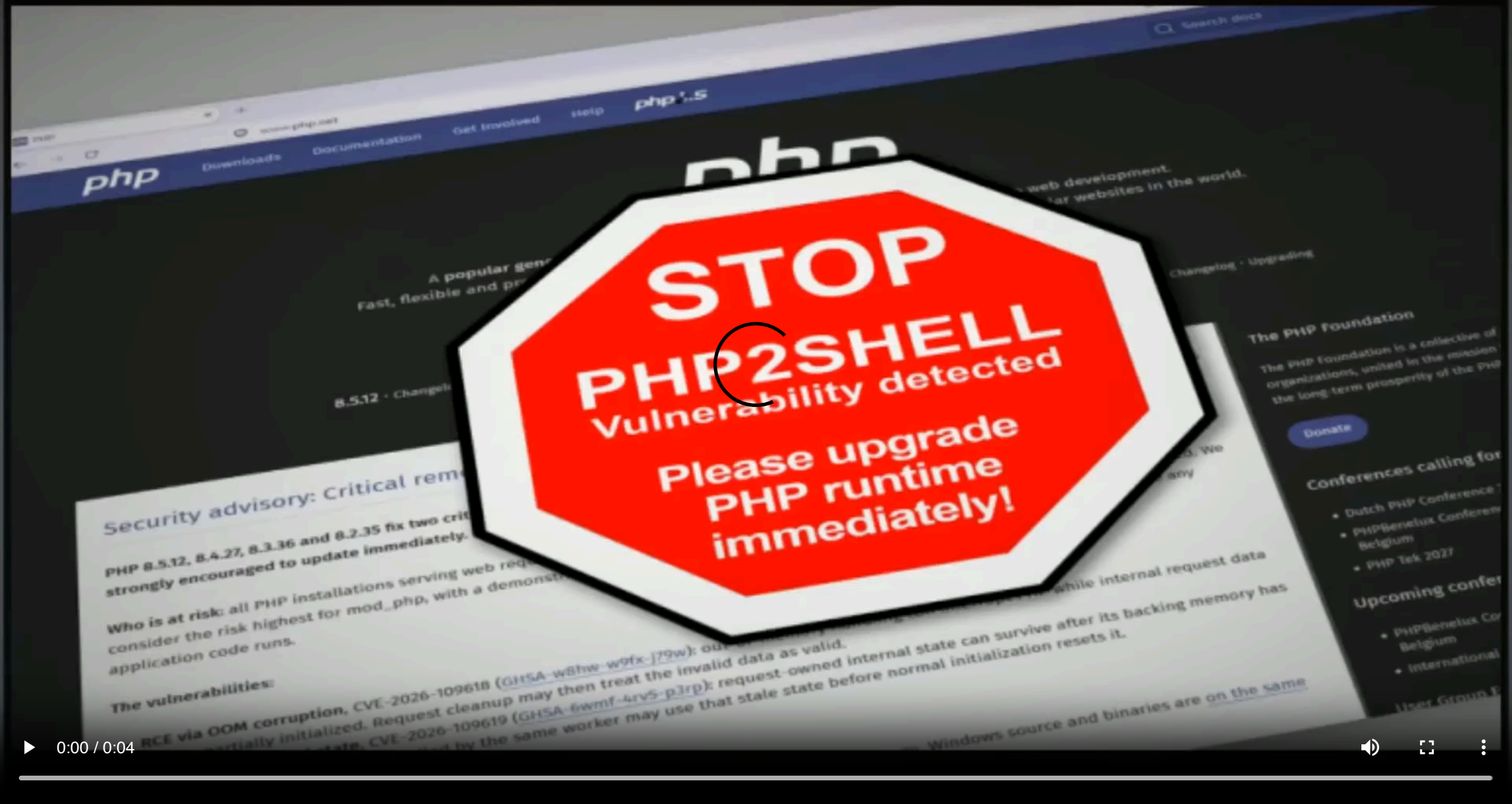
CVE 復現 aka 腳本小子 101

Panda Wu

2026/11/09



https://moon-jam.me/20261109_ncku_cyber_security_course


STOP
PHP2SHELL
Vulnerability detected
Please upgrade
PHP runtime
immediately!
php
Downloads
Documentation
Get involved
Help
Security advisory: Critical
PHP 8.5.12, 8.4.27, 8.3.36 and 8.2.35 fix two
strongly encouraged to update immediately.
Who is at risk: all PHP installations serving web
consider the risk highest for mod_php, with a
application code runs.
The vulnerabilities:
RCE via OOM corruption, CVE-2026-109618 (GHSA-w8hw-w9fx-j79w):
The PHP Foundation
Donate
Conferences calling for
Dutch PHP Conference
PHPBenelux Conference
Belgium
PHP Tek 2027
Upcoming confe
PHPBenelux Co
Belgium
International
0:00 / 0:04

Live Demo

幫自己加分

Before

MANUAL ITEM
Midterm
30.00

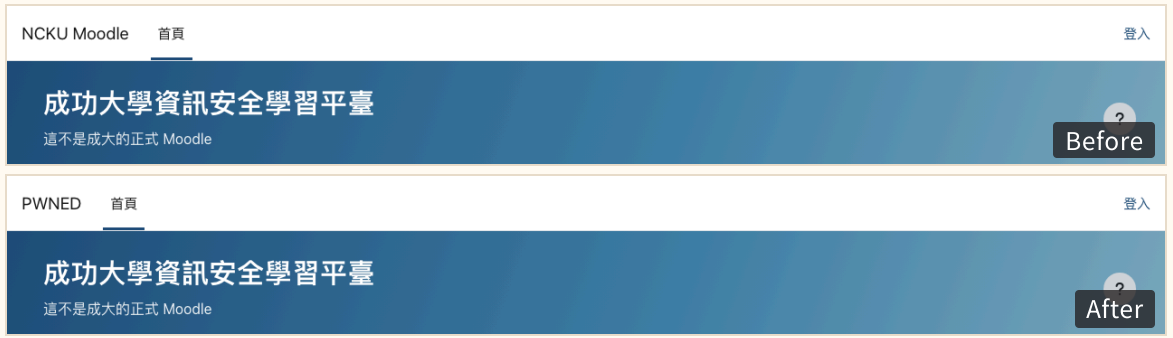
AGGREGATION
Course total
30.00

After

MANUAL ITEM
Midterm
100.00

AGGREGATION
Course total
100.00

PWN Moodle



Good Hacker



~~從入門到入獄~~

第 二 編 分則

第 三十六 章 妨害電腦使用罪

第 358 條	無故輸入他人帳號密碼、破解使用電腦之保護措施或利用電腦系統之漏洞，而入侵他人之電腦或其相關設備者，處三年以下有期徒刑、拘役或科或併科三十萬元以下罰金。
第 359 條	無故取得、刪除或變更他人電腦或其相關設備之電磁紀錄，致生損害於公眾或他人者，處五年以下有期徒刑、拘役或科或併科六十萬元以下罰金。
第 360 條	無故以電腦程式或其他電磁方式干擾他人電腦或其相關設備，致生損害於公眾或他人者，處三年以下有期徒刑、拘役或科或併科三十萬元以下罰金。
第 361 條	對於公務機關之電腦或其相關設備犯前三條之罪者，加重其刑至二分之一。
第 362 條	製作專供犯本章之罪之電腦程式，而供自己或他人犯本章之罪，致生損害於公眾或他人者，處五年以下有期徒刑、拘役或科或併科六十萬元以下罰金。
第 363 條	第三百五十八條至第三百六十條之罪，須告訴乃論。

資安倫理宣傳

本分享目的在提升與會者對資訊安全之認識及資安實務能力，深刻體認到資安的重要性！所有學習內容不得從事非法攻擊或違法行為，所有非法行為將受法律規範，提醒與會者不要以身試險。

Outline

01 **理解網站與驗證 PoC**

認識 HTTP、PHP 與 Moodle，並在最小環境中重現漏洞。

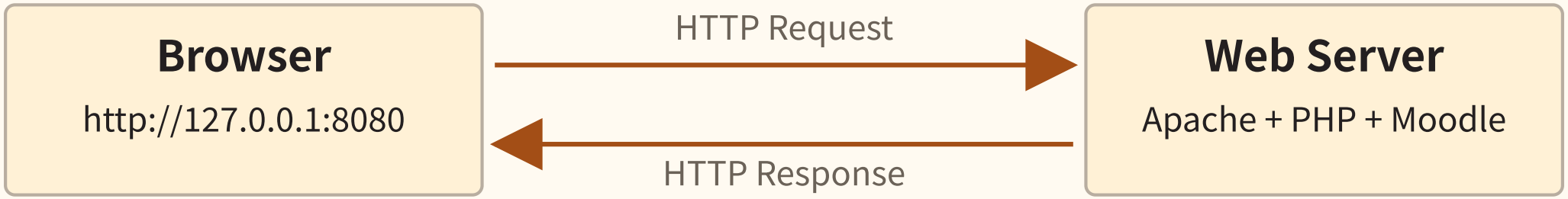
02 **在 Moodle 上實作 PHP2Shell**

取得執行證據與 Flag，觀察漏洞對網站及資料的影響。

03 **理解漏洞原理與修補**

拆解 PHP2Shell 的運作原理，並比較修補前後的結果。

瀏覽器如何與網站溝通？



127.0.0.1 是自己的電腦；8080 用來指定這個網站服務。

HTTP Request / Response

- **Request Method** / **Status Code**
- **Headers**：補充訊息的條件與資訊，例如內容格式或 Cookie。
- **Body**：Request 可以沒有；Response 放實際傳回的內容。

HTTP Request

GET /index.php HTTP/1.1 Request Line

Header Fields
Host: 127.0.0.1:8080
Cookie: MoodleSession=…

Message Body（可選）
name=value

HTTP Response

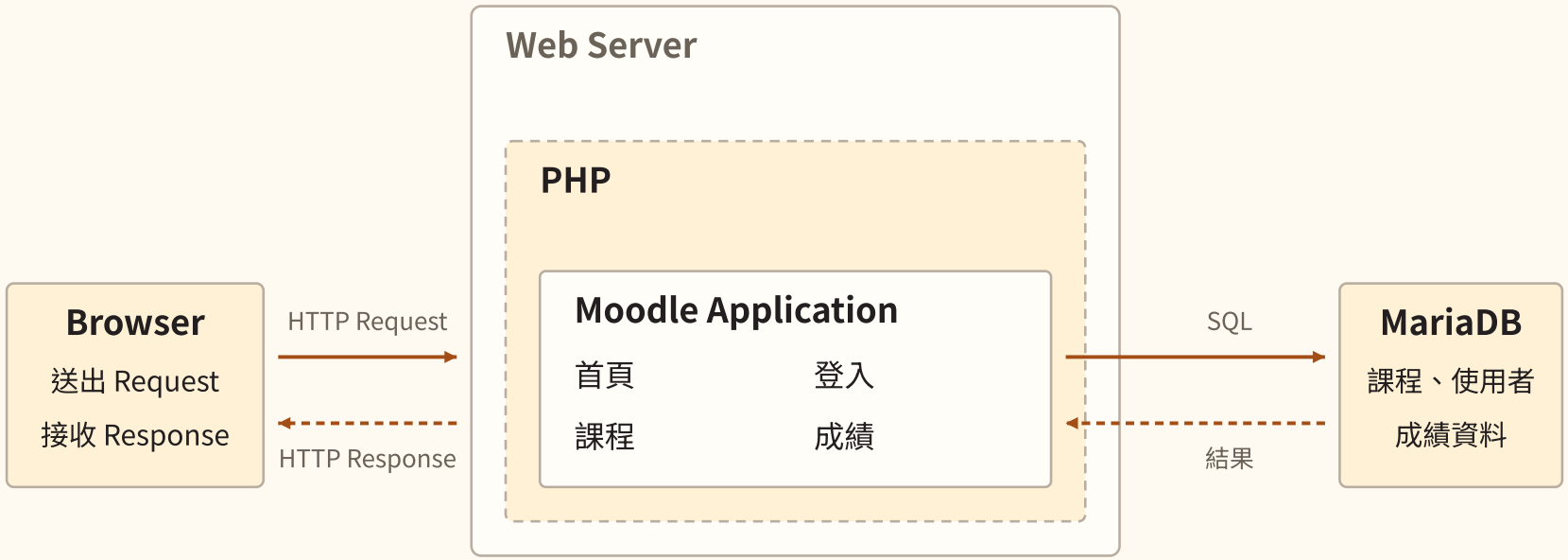
HTTP/1.1 200 OK Status Line

Header Fields
Content-Type: text/html
Set-Cookie: PHPSESSID=…

Message Body
<html>…</html>

Moodle 如何讀寫資料？

Moodle 的網站資料流



PHP 在伺服器上執行

hello.php

```
<?php
echo "OK";
?>
```

http://localhost/hello.php

OK

漏洞 / CVE

- **漏洞（Vulnerability）**：軟體或系統中的安全弱點，可能被利用而造成安全問題。
- **CVE（Common Vulnerabilities and Exposures）**：公開漏洞的識別編號，方便查詢漏洞資訊及修補方式。
- **本次案例**：CVE-2026-109618、CVE-2026-109619

0-day vs. N-day

0-day

修補公開前遭利用

N-day

修補公開後仍遭利用

修補版本發布

What is RCE ?

控制端

```
$ id
```

透過網路送出指令。

目標網站

```
uid=33(www-data)
```

指令在網站服務帳號下執行。

`id(1)` — Linux manual page

PHP2Shell 小故事

2024｜發現潛在漏洞

PHP 在外部安全稽核期間發現記憶體耗盡相關問題，但尚未確認具體的攻擊方式。由於修補可能影響相容性或引入其他問題，修補工作多次延遲。

2026/08｜確認遠端程式碼執行

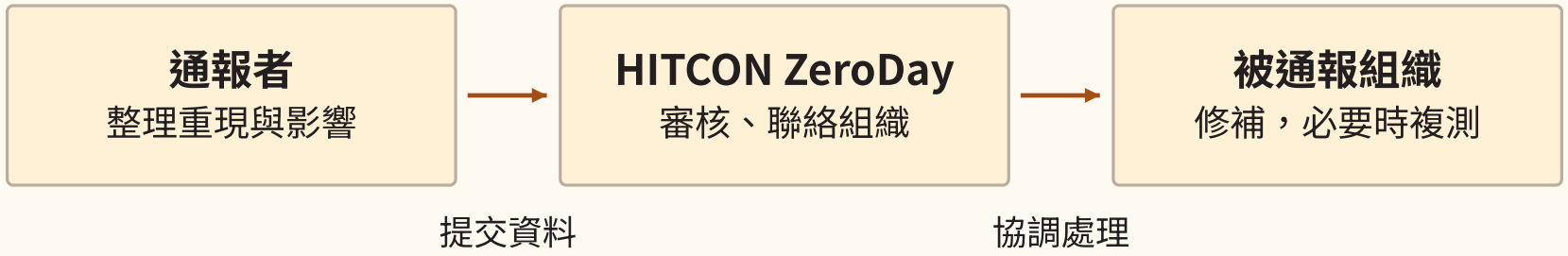
Calif、OpenAI 與 Wiz 等研究團隊先後發現可利用的漏洞路徑，並向 PHP 安全團隊通報。部分研究利用 AI 協助分析，並在 WordPress、Drupal 等網站應用程式中驗證。

2026/10/20–21｜提前揭露與修補

漏洞編號提前流傳，PHP 將修補日期提前一天。隨後 PoC 展示影片意外公開，Chainguard 也提前發布修補映像。PHP 最終於 10 月 21 日發布安全更新。

Timeline

HITCON ZeroDay



開始實驗！

```
git pull origin main
```

Lab 0: Upstream Minimal Target



為什麼不直接在 Moodle 測試？

在完整 Moodle 上失敗

- 漏洞真的存在嗎？
- PoC 的版本與條件符合嗎？
- 是 Moodle 環境，還是 exploit 本身？

先把變因縮小

PHP 8.4.26 + 最小 `echo` 頁面，只保留 request startup 與 offsets。

先確認 PoC 能執行，再把同一條 PoC 移到完整 Moodle。

休息 10 分鐘



在 Moodle 重現漏洞

	最小 Target	Moodle
PHP	`8.4.26`	`8.3.35`
Port	`8088`	`8080`
頁面	echo OK	完整 Moodle
Profile	`official`	`official83`
Container／service	`php2shell-target`	`moodle`（用 `ps -q moodle` 取 ID）

本機 Lab 部署

本機 Host 與 Docker 部署



Browser 只連到 `127.0.0.1:8080`；Moodle 與 MariaDB 在 Docker network 內；DB 沒有對外 port。

Lab 1: Start and Configure Moodle

Lab 2: Read the PoC



Lab 3: Verify Remote Code Execution



Lab 4: Capture The Flag (CTF)

- Payload 最多 14 bytes
- `len("cat /opt/lab/flag.txt") = 21`



RCE?

https://webhook.site/
https://www.revshells.com/

打進 Moodle 資料庫

RCE 取得的是網站程序權限，不是管理員帳號



可讀取的憑證與程式權限，取決於 Lab 的檔案與資料庫設定。

不是 root，也不是 Moodle 管理員登入。

本 Lab 的 `config.php` 含有 DB 連線設定，RCE 後，可以使用這些憑證存取測試資料。

More effects

Lab 5: Front-page Name

`homepage.php`

`NCKU Moodle` → `PWNED`

Lab 6: Fictional Grade

`grade.php 100`

Midterm：`30.00 → 100.00`

Lab 7: Good-hacker Image

`good-hacker.php`



休息 20 分鐘



How to RCE

CVE-2026-109619

Lab 8: Patched PHP Comparison

```
sh scripts/switch-php.sh 8.3.36
python3 php2shell/exploit.py \
  -u http://127.0.0.1:8080/index.php \
  --profile official83 --docker-container "$CONTAINER" \
  --proof-file loot/p1 -c 'id>/loot/p1'
```



Your Turn (10%)



評分標準

項目	配分
說明環境架設	20%
說明 PoC 來源與適用條件	20%
復現攻擊並取得 Flag	30%
補上 Patch 並驗證	20%
實作第四種攻擊效果	10%
Bonus - 說明 PoC 機制	10%
Bonus - 分析 RCE 能造成的其他安全影響，透過實際實驗證據支持結論	10%

$$\text{Final Score} = \min\{100, \text{Base Score} + \text{Bonus}\}$$



Writeup Template

Thanks for listening

本投影片採用

BY-NC-SA 許可協議。轉載請註明出處！

